

CashSouk — External Penetration Test Scope Brief

This brief is for the penetration testing team. It describes the publicly reachable CashSouk platform so you can scope and execute an **external** assessment.

Engagement summary

Item	Detail
Target	CashSouk P2P lending platform
Assessment type	External (internet-facing)
Application region	Malaysia
Protocol	HTTPS only

Fill in the rules-of-engagement table in §8 with the agreed window, contacts, and whether this is black-box or gray-box before testing starts.

1. In-scope hosts

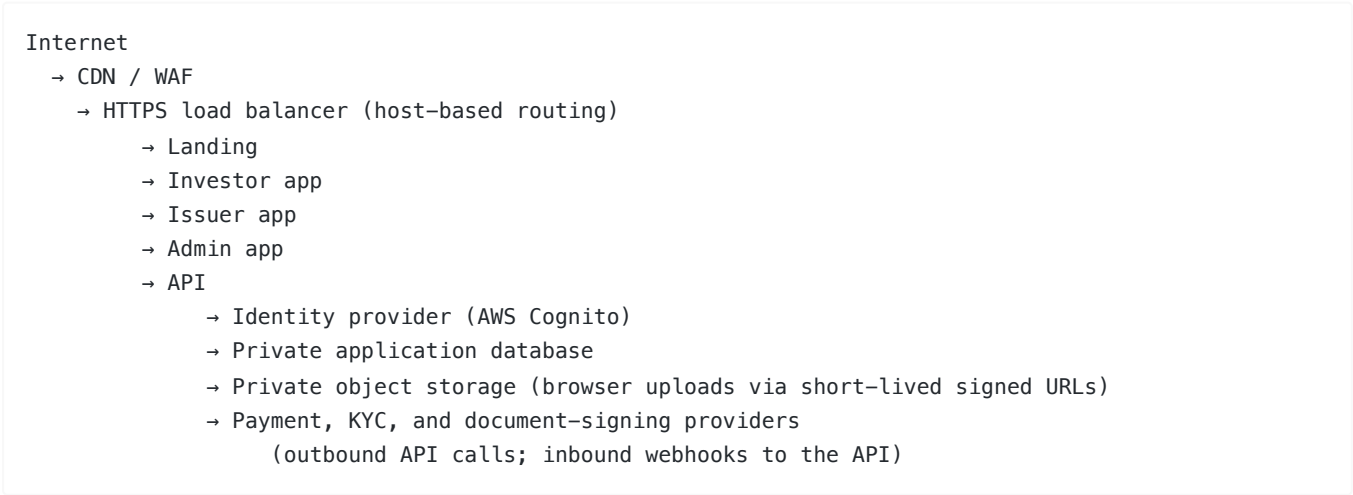
Treat the following hostnames as in scope unless the signed rules of engagement say otherwise:

Hostname	What it is
cashsouk.com	Public landing site and authentication entry
investor.cashsouk.com	Investor web application
issuer.cashsouk.com	Issuer (borrower) web application
admin.cashsouk.com	Administrative web application
api.cashsouk.com	Backend REST API (versioned under /v1)

Confirm DNS, certificates, and reachability for the environment named in the RoE (production or staging) before you begin.

2. System overview

CashSouk is a multi-portal web platform behind a CDN/WAF edge and a load balancer that routes by hostname.



What you should assume from the outside

- The five hostnames above are the intended public surface.
 - Portals authenticate users, then call `api.cashsouk.com`.
 - The database and object storage are not intended to be directly reachable from the internet.
 - Payment and KYC providers may call the API on webhook paths; those inbound callbacks are part of the application surface.
-

3. User roles

Role	Primary host	Access you should expect
Investor	<code>investor.cashsouk.com</code>	Own-organisation investor flows (marketplace, investments, deposits)
Issuer	<code>issuer.cashsouk.com</code>	Own-organisation issuer flows (applications, onboarding, fees, notes)
Admin	<code>admin.cashsouk.com</code>	Privileged platform operations

Authentication is Cognito-based. After login, portals use session/tokens against the API. Authorization is role-based and ownership-based.

Gray-box: you will be given at least one account per role, plus any MFA or email-verification steps required to complete login.

Black-box: no accounts; self-registration paths on the landing site (where available) are fair game within RoE limits.

4. Areas to focus on

Edge and host exposure

- Correct host routing across the five names
- TLS configuration, redirects, and security headers
- Whether origin can be reached in ways that bypass edge protections
- Unnecessary disclosure via errors, health checks, or documentation endpoints

Authentication and session handling

- Login, signup, password reset, and OAuth/redirect behaviour
- Session fixation, token replay, logout completeness
- Moving between roles or portals with a single account where that should not be allowed

API authorization (`https://api.cashsouk.com/v1`)

- Horizontal access between organisations (IDOR / BOLA)
- Vertical privilege escalation into administrative APIs
- Marketplace, wallet/balance, investments, applications, contracts, and signing flows
- CORS and credential handling from portal origins

Payments (priority)

- Deposit and fee checkout flows started from the portals
- Integrity of **inbound payment webhooks** (forgery, replay, out-of-order events)
- Crediting balances or fees without a genuine successful payment
- Race conditions around deposit and investment funding

Onboarding and files

- KYC/KYB status changes driven by provider callbacks
- Uploads via signed URLs (object key abuse, type confusion, unauthorised access to other users' objects)
- Document signing / eKYC callback integrity

Public or weakly gated content

- Unauthenticated catalogue or legal-document endpoints, if present

- Over-disclosure in API error responses

5. Third-party services you will encounter

You may see traffic or redirects involving these providers. Test **CashSouk's integration** (redirects, webhooks, signed upload URLs). Do **not** attack the vendor platforms themselves unless that is separately contracted.

Provider	Role in the system
AWS Cognito	User authentication
Curlec (Razorpay)	FPX payments and related webhooks
RegTank	KYC / KYB onboarding and status callbacks
Signing / eKYC provider	Contract signing flows and callbacks
Cloud object storage	File uploads via short-lived signed URLs

6. Recommended test lanes

Lane	Objective
AuthZ / RBAC	Show that a lower-privilege user cannot reach admin functions or another organisation's data
Money movement	Show that forged, replayed, or raced payment events cannot incorrectly credit funds
Onboarding & files	Show that KYC status or uploaded documents cannot be forged or accessed across tenants
Edge exposure	Confirm only the intended public services are reachable

7. Out of scope

Unless the signed rules of engagement explicitly expand scope, do **not**:

- Perform denial-of-service or volumetric flooding
- Conduct social engineering or phishing of staff
- Test physical security
- Target third-party vendor infrastructure (Cognito console, Curlec, RegTank, etc.) as a primary objective
- Attempt access to private cloud resources that are not reachable via the public hosts above, except as a finding that demonstrates an exposure from the internet

8. Rules of engagement (to be completed)

Item	Agreed value
Environment	Production / Staging (specify)
Assessment style	Black-box / Gray-box
Testing window	
Allowed hours / timezone	
Rate-limit / WAF expectations	
Test accounts (if gray-box)	Investor / Issuer / Admin

Emergency / stop-test contact	
Report format & severity scale	
Data handling / PII constraints	

9. Deliverables from you

Provide findings with clear reproduction steps, affected host/endpoint, impact, and severity, covering at minimum:

1. Unauthenticated external exposure
2. Authenticated authorisation failures (cross-role and cross-organisation)
3. Payment and webhook integrity issues
4. Session / authentication weaknesses
5. Sensitive data exposure in responses or client-side storage

Use the severity scale named in §8.